

TC6 - TP05 Kali Linux- Analyse réseau

Informez les utilisateurs et mettez en œuvre les défenses appropriées.,

NMAP & Wireshark

Objectif TP05

L'objectif de ce TP est d'installer un VM Kali Linux et de manipuler un outil d'écoute de réseau avec **Wireshark**, de réaliser une cartographie du réseau, scanner des ports avec **nmap**.

Attendus

Un compte-rendu de TP. Présentation de Kali Linux. Présentation de NMAP + Progression dans le TP.

Qu'est-ce-que NMAP ?

Nmap est un outil de scan de ports et de découverte de réseau. Il envoie des paquets spécifiques (comme des requêtes TCP, UDP ou ICMP) pour interroger les hôtes sur un réseau et analyser les réponses afin de déterminer quels ports sont ouverts, quels services sont en cours d'exécution, et d'autres informations sur les hôtes.

Qu'est-ce-que Wireshark ?

Wireshark est un analyseur de protocole qui capture et enregistre tout le trafic réseau qui passe par une interface réseau. Il permet d'examiner en détail chaque paquet, d'analyser les protocoles et de visualiser le contenu des communications.

En résumé, Nmap est utilisé pour scanner et découvrir des informations sur les hôtes d'un réseau, tandis que Wireshark est utilisé pour capturer et analyser le trafic réseau en temps réel.

Qu'est-ce qu'une capture réseau ?

Une capture réseau est une photo à un instant t (ou sur une période de temps t_0/t_1) de ce qui transite sur un réseau informatique. Si l'on choisit bien le point de capture, on pourra sauvegarder l'ensemble d'un trafic intéressant pour ensuite l'analyser à tête reposée.

Une capture réseau pour quoi faire ?

Les principales applications d'une capture puis d'une analyse réseau sont:

- identifier les flux consommateurs sur une liaison Internet, WAN ou LAN
- caractériser le trafic généré par une nouvelle application
- identifier les causes d'un problème de performance sur un réseau (tempête de broadcast ou problème physique sur un équipement).

Où effectuer la capture réseau avec Wireshark ?

C'est un des points critiques. Il faut effectivement se positionner à un endroit où l'on va capturer l'ensemble du trafic "intéressant" par rapport à votre besoin sans pour autant sauver des gigaoctets d'informations.

Pour analyser les flux d'une liaison WAN, le plus simple est de faire la capture au plus proche de l'interface réseau de sortie vers cette liaison. Si cette liaison n'est pas une liaison Ethernet, alors il faudra se positionner en amont du routeur gérant cette liaison.

Pour analyser une nouvelle application, le plus simple est de capturer le trafic sur un des PC clients ou sur le serveur dans le cas d'une architecture client/serveur).

VM Kali Linux

Si le clavier est en Qwerty alors changer dans le terminal.

```
# sudo dpkg-reconfigure keyboard-configuration
```

La VM doit être posséder 2 cartes réseau, 1 en NAT et 1 en Réseau privé hôte.

Attendus

Un compte-rendu de TP. Présentation de Kali Linux. Progression dans le TP.

Avertissement

Les outils abordés dans ce TP sont uniquement utilisés des fins éthiques (Ethical Hacking) et pédagogiques. Leur usage est formellement interdit en dehors de ce cadre sur un réseau tiers sans autorisation explicite.

Activité 1 - NMAP : découvertes des machines et des services

➡ A l'invite du terminal, saisissez man nmap.

```
$ man nmap
```

➡ Qu'est-ce que Nmap ?

➡ À quoi Nmap sert-il ?

Lorsque vous êtes sur la page du manuel, vous pouvez utiliser les touches fléchées haut/bas pour faire défiler les pages. Vous pouvez également appuyer sur la barre d'espace pour avancer d'une page à la fois.

Pour rechercher un terme ou une expression spécifique, saisissez une barre oblique (/) ou un point d'interrogation (?) suivi de ce terme ou de cette expression. La barre oblique permet d'effectuer une recherche vers l'avant dans tout le document, tandis que le point d'interrogation effectue une recherche en arrière dans le document. La touche n permet d'accéder à la correspondance suivante.

➡ Saisissez /exemple et appuyez sur ENTRÉE. Cette opération permet de rechercher le mot exemple vers l'avant dans les pages du manuel.

```
Terminal - analyst@secOps:~
File Edit View Terminal Tabs Help
NMAP(1)                                Nmap Reference Guide                                NMAP(1)
NAME
  nmap - Network exploration tool and security / port scanner
SYNOPSIS
  nmap [Scan Type...] [Options] {target specification}
DESCRIPTION
  Nmap ("Network Mapper") is an open source tool for network exploration
  and security auditing. It was designed to rapidly scan large networks,
  although it works fine against single hosts. Nmap uses raw IP packets
  in novel ways to determine what hosts are available on the network,
  what services (application name and version) those hosts are offering,
  what operating systems (and OS versions) they are running, what type of
  packet filters/firewalls are in use, and dozens of other
  characteristics. While Nmap is commonly used for security audits, many
  systems and network administrators find it useful for routine tasks
  such as network inventory, managing service upgrade schedules, and
  monitoring host or service uptime.

  The output from Nmap is a list of scanned targets, with supplemental
  information on each depending on the options used. Key among that
  /example
```

a. Dans le premier exemple, trois correspondances s'affichent. Pour accéder à la correspondance suivante, appuyez sur n.

```
Terminal - analyst@secOps:~
File Edit View Terminal Tabs Help
A typical Nmap scan is shown in Example 1. The only Nmap arguments used
in this example are -A, to enable OS and version detection, script
scanning, and traceroute; -T4 for faster execution; and then the
hostname.

Example 1. A representative Nmap scan

# nmap -A -T4 scanme.nmap.org

Nmap scan report for scanme.nmap.org (74.207.244.221)
Host is up (0.029s latency).
rDNS record for 74.207.244.221: 1186-221.members.linode.com
Not shown: 995 closed ports
PORT      STATE      SERVICE      VERSION
22/tcp    open      ssh          OpenSSH 5.3p1 Debian 3ubuntu7 (protocol
2.0)
| ssh-hostkey: 1024 8d:60:f1:7c:ca:b7:3d:0a:d6:67:54:9d:69:d9:b9:dd (
DSA)
|_ 2048 79:f8:09:ac:d4:e2:32:42:10:49:d3:bd:20:82:85:ec (RSA)
80/tcp    open      http        Apache httpd 2.2.14 ((Ubuntu))
|_ http-title: Go ahead and ScanMe!
646/tcp   filtered  ldp
1720/tcp  filtered  H.323/Q.931

Manual page nmap(1) line 44 (press h for help or q to quit)
```

Regardez l'exemple 1.

- ➡ Quelle est la commande nmap utilisée ?
- ➡ Utilisez la fonction de recherche pour répondre aux questions suivantes.
 - À quoi sert le commutateur -A ?
 - À quoi sert le commutateur -T4 ?
- ➡ Faites défiler la page pour en savoir plus sur nmap. Saisissez « q » lorsque vous avez terminé

1 Découverte du réseau avec map

- ➡ Effectuez une découverte d'hôtes, et déterminez les adresses IP+MAC des hôtes en ligne se trouvant dans le même réseau que Kali (utilisez l'option -sP)
nmap -sP 192.168.50.0/24

- ➡ Lancer un scan en ciblant la machine locale (Kali) et déterminez les services ouverts ainsi que le système d'exploitation, lancez ftp et http ensuite relancez le scan

#nmap -sS -O @IP de la VMKali

- ➡ Lancer un scan en ciblant le routeur :

#nmap -sS -O 192.168.50.1

- ➡ De quelle façon peut-on cibler plusieurs machines avec une seule exécution de la commande ?
- ➡ Comment scanner une plage d'adresses IP de classe C ?
- ➡ Lancez un sniffing Wireshark sur Kali, ensuite effectuez deux scan nmap de types « scan TCP SYN » et « scan Xmas » respectivement. Examinez les paquets capturés associés à chacune des deux techniques de scan et déterminez la différence entre elles.

II.2 Analyse des ports ouverts sur un réseau

Dans cette partie, vous allez utiliser les commutateurs issus de l'exemple des pages de manuel Nmap pour analyser votre hôte local, votre réseau local et un serveur distant.

AVERTISSEMENT : avant d'utiliser Nmap sur un réseau, demandez l'autorisation des propriétaires du réseau. En particulier le scan d'un hôte distant n'est pas autorisé sauf s'il s'agit d'un « bac à sable », d'un « pot de miel » ou tout hôte pour lequel vous en avez l'autorisation.

a. Analysez votre hôte local

- b. Si nécessaire, ouvrez un terminal sur la machine virtuelle. À l'invite, saisissez **nmap -A -T4 localhost**. Selon votre réseau local et vos périphériques, l'analyse peut durer de quelques secondes à quelques minutes.

```
$ nmap -A -T4 localhost
```

```
Starting Nmap 7.40 ( https://nmap.org ) at 01/05/2017 17:20 EDT
```

```
Nmap scan report for localhost (127.0.0.1)
```

```
Host is up (0.000056s latency).
```

```
Other addresses for localhost (not scanned): ::1
```

```
rDNS record for 127.0.0.1: localhost.localdomain
```

```
Not shown: 996 closed ports
```

```
PORT STATE SERVICE VERSION
```

```
21/tcp open  ftp vsftpd 2.0.8 or later
```

```
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
```

```
|_rw-r--r-- 1 0 0 0 Apr 19 15:23 ftp_test
```

```
<some output omitted>
```

- c. Vérifiez les résultats et répondez aux questions suivantes.

- ➡ Quels sont les ports et les services ouverts ?
- ➡ Pour chacun des ports ouverts, notez le nom de l'application qui fournit le service.

3 Analysez le réseau local

AVERTISSEMENT : avant d'utiliser Nmap sur un réseau, demandez l'autorisation des propriétaires du réseau.

d. À l'invite de commande du terminal, saisissez **ip address** pour déterminer l'adresse IP et le masque de sous-réseau de cet hôte. Dans cet exemple, l'adresse IP de cette machine virtuelle est 192.168.50.xx et le masque de sous-réseau est 255.255.255.0.

```
$ ip address
<output omitted>

2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default
qlen 1000

    link/ether 08:00:27:ed:af:2c brd ff:ff:ff:ff:ff:ff

    inet 192.168.50.xx/24 brd 192.168.1.255 étendue dynamique globale enp0s3
    valid_lft 85777sec preferred_lft 85777sec

    inet6 fe80::a 00:27 ff:feed:af2c/64 lien de portée
    valid_lft forever preferred_lft forever
```

Enregistrez l'adresse IP et le masque de sous-réseau de votre machine virtuelle.

➡ À quel réseau votre machine virtuelle appartient-elle ?

e. Pour localiser les autres hôtes sur ce réseau local, saisissez **nmap -A -T4 network address/prefix**. Le dernier octet de l'adresse IP doit être remplacé par un zéro. Par exemple, l'adresse IP 192.168.1.xx, où .15 correspond au dernier octet. Par conséquent, l'adresse réseau est 10.0.2.0. /24 est le préfixe. Il s'agit du raccourci pour le masque de sous-réseau 255.255.255.0. Si le masque de réseau votre machine virtuelle est différent, recherchez votre préfixe dans le «tableau de conversion CIDR» sur Internet. Par exemple, 255.255.0.0 correspond à /16. L'adresse réseau 10.0.2.0/24 est utilisée dans cet exemple

Remarque : cette opération peut prendre un certain temps, surtout si plusieurs périphériques sont connectés au réseau. Dans l'environnement de test, l'analyse a pris environ 4 minutes.

```
$ nmap -A -T4 192.168.50.0/24
Starting Nmap 7.40 ( https://nmap.org ) at 01/05/2017 17:13 EDT
<output omitted>
Nmap scan report for 192.168.1.xx
Host is up (0.00019s latency).
Not shown: 997 closed ports
PORT STATE SERVICE VERSION
21/tcp open  ftp vsftpd 2.0.8 or later
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r- 1 0 0 0 26 mars 2018 ftp_test
| ftp-syst:
| STAT:
| FTP server status:
| Connected to 192.168.1.xx
| Logged in as ftp
| TYPE: ASCII
| No session bandwidth limit
| Session timeout in seconds is 300
| Control connection is plain text
| Data connections will be plain text
| At session startup, client count was 1
| vsFTPD 3.0.3 - secure, fast, stable
|_ End of status
22/tcp open  ssh OpenSSH 8.2 (protocol 2.0)
23/tcp open  telnet Openwall GNU/*/Linux telnetd
Service Info: Host: Welcome; OS: Linux; CPE: cpe:/o:linux:linux_kernel
Post-scan script results:
|_ clock-skew:
|_ 0s:
|_ ...
```

```
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (x hosts up) scanned in 346.89 seconds
```

- ➡ Dans l'exemple ci-dessus, combien d'hôtes sont actifs ?
- ➡ Quelles adresses IP et quels ports et services sont ouverts ?
- ➡ Dans vos résultats Nmap, **nmap -A -T4 network address/prefix** avec *address* et *prefix* correspondants au réseau de la machine virtuelle
- ➡ Combien d'hôtes sont actifs ?
- ➡ Répertoriez les adresses IP des hôtes qui se trouvent sur le même réseau local que votre machine virtuelle.
- ➡ Répertoriez les services qui sont disponibles sur les ordinateurs hôtes détectés.

II.3 Analyse du site web scanne.nmap.org

Scanme.nmap.org : est un site géré par les développeurs de Nmap, conçu spécifiquement pour que les utilisateurs puissent tester Nmap. Vous pouvez effectuer des scans sur ce domaine, car il est destiné à cet usage.

Ping l'hôte avec la commande ping pour obtenir l'adresse IP

ping "www.nom d'hôte.com"

Entrer la commande suivante : nmap -sV adresse ip de votre cible

Il affichera tous les détails capturés de l'hôte.

Question de réflexion

Nmap est un outil puissant pour l'exploration et la gestion du réseau. Comment Nmap peut-il contribuer à la sécurité du réseau ?

- ➡ Comment Nmap peut-il être utilisé par un hacker comme outil néfaste ?

Portqry est un outil microsoft en ligne de commandes équivalent à nmap qui peut être utilisé sur un ordinateur

[windows](https://docs.microsoft.com/fr-fr/troubleshoot/windows-server/networking/portqry-command-line-port-scanner-v2)[https://docs.microsoft.com/fr-fr/troubleshoot/windows-server/networking/portqry-command-line-port-scanner-](https://docs.microsoft.com/fr-fr/troubleshoot/windows-server/networking/portqry-command-line-port-scanner-v2)

[v2](https://docs.microsoft.com/fr-fr/troubleshoot/windows-server/networking/portqry-command-line-port-scanner-v2) **Zenmap** est la version « graphique » de nmap disponible pour Linux, Mac, Windows <https://nmap.org/zenmap/>

Code pénal

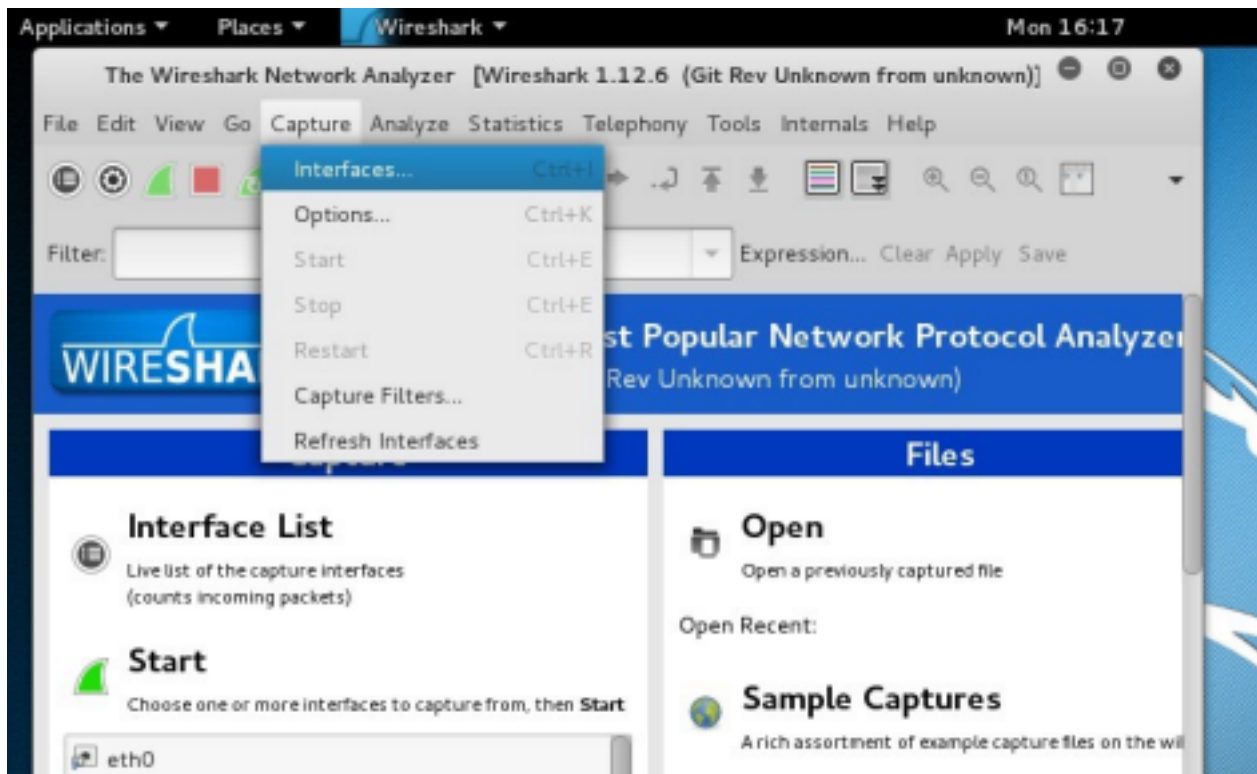
Pour rappel, l'article 323-1 du code pénal stipule que le fait d'accéder ou de se maintenir, frauduleusement, dans tout ou partie d'un système de traitement automatisé de données est puni de deux ans d'emprisonnement et de 60 000 € d'amende.

Lorsqu'il en est résulté soit la suppression ou la modification de données contenues dans le système, soit une altération du fonctionnement de ce système, la peine est de trois ans d'emprisonnement et de 100 000 € d'amende.

https://www.legifrance.gouv.fr/codes/article_lc/LEGIARTI000030939438/

Activité II - Wireshark : Lancer une capture de

trames ? Lancer l'application Wireshark. Vous devriez voir apparaître une fenêtre similaire à celle-ci :

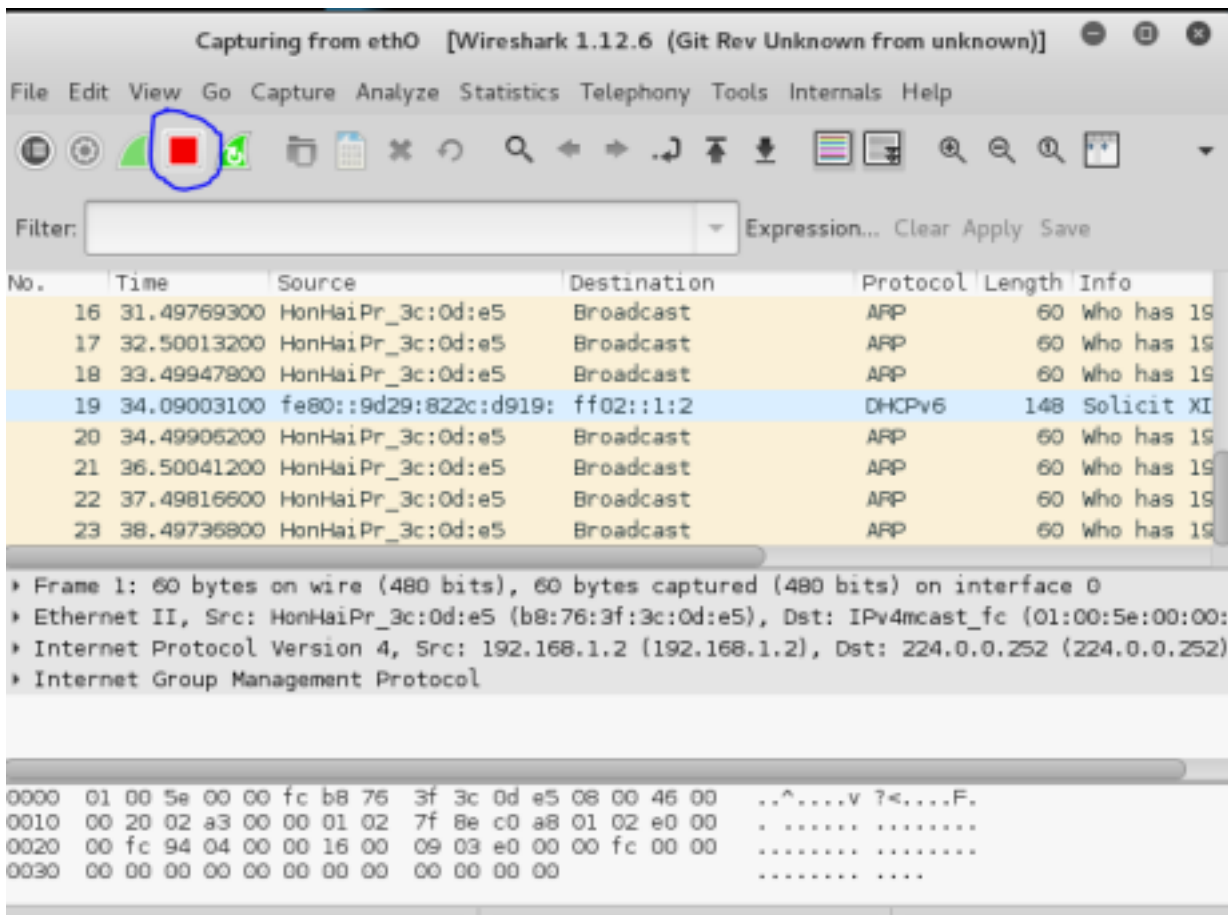


Dans le menu capture, sélectionner le sous-menu Interfaces et lancer une capture de trame sur la carte réseau portant votre adresse IP et appuyer sur Start



Arrêter la capture en cliquant sur le bouton arrêter en rouge (voir image ci-dessous).

Une fois la capture effectuée, vous obtiendrez la fenêtre suivante :



Travail à faire :

a. Analyse de la capture du ping

- ➔ Démarrer la machine virtuelle Kali en mode « *host only* »
- ➔ A partir de Kali, lancez l'outil wireshark, et lancez la capture de trafic sur l'interface eth0
- ➔ A partir de la hôte, lancez un ping vers la machine Kali
- ➔ Attendez jusqu'à ce que le ping soit terminé, ensuite arrêtez la capture wireshark sur Kali
- ➔ Analysez les PDU capturés et répondez aux questions suivantes :
- ➔ Quelle est l'adresse source des paquets en destination de Kali
- ➔ Le Ping utilise-t-elle un protocole de la couche transport ? si, oui, lequel ?
- ➔ Quel est le protocole de la couche réseau (IP) utilisés par Ping ?
- ➔ Quel est le type de message (icmp) envoyés par ping ?
- ➔ Quel est le type de message (icmp) de réponses envoyés par Kali ?

b. Analyse de la capture de traceroute

- ➔ A partir de Kali, lancez l'outil Wireshark, et lancez la capture de trafic sur eth0
- ➔ A partir de la hôte, lancez la commande 'tracert @ip Kali' vers la machine Kali ➔ Attendez jusqu'à ce que tracert soit terminé, ensuite arrêtez la capture Wireshark sur Kali
- ➔ Analysez les PDU capturés et répondez aux questions suivantes :
 - traceroute utilise-t-il un protocole de la couche transport ?

- quel est le protocole de la couche réseau utilisé par traceroute ?
- Comment fonctionne la commande traceroute ?
- Dans les PDU de la couche réseau envoyés par la hôte, quelle est la valeur du champ Time to Live ?

c. Analyse de la capture d'une interaction avec un serveur Web

- ➡ A partir de la Kali, lancez le serveur web apache : `# service apache2 start`
Si il n'est pas installé dans le terminal #apt-get install apache2
- ➡ Vérifiez que le serveur web est lancé par la commande : `netstat -antp`
- ➡ A partir de la Kali, lancez l'outil Wireshark, et lancez la capture de trafic sur eth0
- ➡ A partir de la hôte, ouvrez le navigateur web, et taper l'adresse `http://@ip-de-Kali` pour accéder au serveur web de Kali.
- ➡ Attendez jusqu'à ce qu'une page web s'affiche sur le navigateur web, ensuite arrêtez la capture Wireshark.
- ➡ Analysez les PDU capturés par Wireshark et répondez aux questions suivantes :
- ➡ Quel est le protocole de la couche de transport utilisé durant cette interaction ➡ Identifiez les paquets d'établissements de connexion TCP, et en extraire les numéros de séquences et d'acquittements
- ➡ Quel est le protocole de la couche application utilisé
- ➡ Quel est le port source, et le port de destination
- ➡ Quel est le type de requête envoyé par le client pour afficher la page web.
- ➡ Quel est la version du serveur web utilisé.

Fichier auto capture :

<https://www.wireshark.org/download/automated/captures/>